

INSA NATIONAL ETHIO CYBER TALENT WEEKEND PROGRAM

BLUE TEAM FUNDAMENTALS

A Comprehensive Research Reference

01

Blue Teaming

02

Types of Logs

03

5W1H
Framework

04

SOC Analysis

05

Incident
Response

06

Cyber Threat
Intelligence

07

Log Analysis

Cybersecurity Track • Blue Team & Defense • 2025

Definition & Core Concept

Blue Teaming refers to the defensive side of cybersecurity — a group of security professionals whose mission is to **detect, respond to, and prevent** cyber attacks against an organization. While Red Teams simulate attackers, Blue Teams simulate and operate the defenders. They maintain continuous visibility over an organization's environment and act as the last line of defence.

Blue Team Mission Statement

Protect the confidentiality, integrity, and availability (CIA) of organizational assets.

Detect malicious activity as early as possible in the attack lifecycle.

Respond to incidents swiftly to minimize damage and dwell time.

Continuously harden defences based on threat intelligence and lessons learned.

Key Blue Team Responsibilities

- **Continuous Monitoring:** 24/7 observation of network traffic, endpoints, and logs via SIEM platforms.
- **Threat Detection:** Identifying indicators of compromise (IoCs) and anomalous behaviour.
- **Vulnerability Management:** Regular scanning, patching, and remediation of weaknesses.
- **Incident Response:** Executing playbooks when a security event is confirmed.
- **Threat Hunting:** Proactively searching for hidden threats that evade automated detection.
- **Security Hardening:** Configuring firewalls, EDR, IDS/IPS, and access controls.
- **Security Awareness:** Training staff to recognise phishing and social engineering.
- **Purple Team Collaboration:** Working with Red Teams to validate and improve controls.

Blue Team vs Red Team vs Purple Team

Team	Role	Mindset	Primary Tools
Blue Team	Defend & Detect	Defender	SIEM, EDR, Firewall, IDS/IPS
Red Team	Attack & Exploit	Attacker	Metasploit, Cobalt Strike, Nmap
Purple Team	Validate & Improve	Collaborator	Both sets + ATT&CK Framework

MITRE ATT&CK Framework and the Blue Team

The MITRE ATT&CK framework is the Blue Team's primary reference for understanding adversary tactics, techniques, and procedures (TTPs). It maps 14 tactical categories — from Initial Access through Exfiltration

— enabling defenders to build detection rules aligned to real-world attack patterns.

- **Tactics:** The adversary's high-level goal (e.g., Persistence, Lateral Movement).
- **Techniques:** How the tactic is achieved (e.g., T1078 – Valid Accounts).
- **Sub-techniques:** Specific implementations of a technique.
- **Mitigations:** Recommended controls to prevent each technique.
- **Detections:** Data sources and queries to detect each technique.

What Are Logs?

Logs are timestamped records of events generated by operating systems, applications, network devices, and security tools. They form the primary data source for detection, forensics, and compliance. Without comprehensive logging, a Blue Team is essentially blind.

System Logs

OS-level

- Generated by the operating system kernel and system services.
- Examples: Windows Event Logs (Security, System, Application), Linux syslog/journald.
- Key events: login attempts, privilege escalation, service start/stop, crash reports.
- Windows Event IDs to know: 4624 (logon), 4625 (failed logon), 4688 (process creation), 4720 (account created).

Network Logs

Traffic-level

- Capture traffic metadata, flows, and full packet captures between network nodes.
- Sources: firewalls, routers, IDS/IPS, proxies, NetFlow collectors.
- Key data: src/dst IP, port, protocol, bytes transferred, connection state, action (allow/deny).
- Tools: Zeek (Bro), Wireshark/tshark, Suricata, pfSense logs.

Application Logs

App-level

- Produced by web servers, databases, custom applications, and middleware.
- Examples: Apache/Nginx access logs, IIS logs, MySQL query logs, API gateway logs.
- Key fields: HTTP method, URI, status code, user agent, response time, error messages.
- Critical for detecting web application attacks: SQLi, XSS, path traversal, IDOR.

Security Logs

Security-tool-level

- Generated by dedicated security products: AV, EDR, DLP, WAF, SIEM.
- Examples: Defender for Endpoint alerts, CrowdStrike detections, Snort alerts.
- Contain threat scores, MITRE technique tags, file hashes, and remediation actions.

Authentication Logs

Identity-level

- Track identity and access events across all systems.
- Sources: Active Directory, LDAP, RADIUS, SAML/SSO providers, VPN concentrators.
- Critical events: brute-force patterns, impossible travel, MFA bypass attempts, account lockouts.
- Key Windows Event IDs: 4771 (Kerberos pre-auth failure), 4776 (NTLM auth).

DNS Logs

Resolution-level

- Record every DNS query and response made by hosts on the network.
- Reveal C2 beaconing via domain generation algorithms (DGA), DNS tunnelling, fast-flux domains.
- High-value for threat hunting: rare domains, long subdomains, high-frequency lookups.
- Tools: Pi-hole logs, BIND query logs, Zeek DNS log, DNS Guardian.

Cloud Logs

Cloud-level

- AWS CloudTrail, Azure Activity Log, GCP Cloud Audit Logs record all API calls and admin actions.
- Critical for detecting cloud misconfigurations, privilege escalation, data exfiltration via cloud storage.
- Key events: IAM policy changes, bucket ACL modifications, root account usage, new key creation.

Email Logs

Communication-level

- Track email delivery, sender reputation, attachment hashes, and link clicks.
- Sources: Exchange/O365 Message Trace, Postfix logs, spam filter reports.
- Primary vector for phishing, BEC (Business Email Compromise), and malware delivery.

The 5W1H Framework — What, When, How, Where, Who, Why

The 5W1H model (What, When, Where, Who, How, Why) is the investigative framework used by analysts during incident investigation and log analysis. Every security event should be fully characterised by answering all six questions before a conclusion is drawn.

WHAT

What happened?

Event Type	Type of security event — malware execution, unauthorised access, data exfiltration, policy violation.
Affected Asset	Which system, application, or data store was involved?
Action Taken	What specific action occurred — file write, network connection, registry modification?
Artefacts	File hashes (MD5/SHA256), process names, registry keys, URLs, domain names.

WHEN

When did it happen?

Timestamp	Exact date and time of the event in UTC (always normalise to UTC).
Duration	How long did the activity persist? Short bursts vs. sustained activity have different implications.
Sequence	Timeline of related events before, during, and after the incident.
Recurrence	Is this a one-off or a recurring pattern? Periodic beaconing, scheduled tasks.

WHERE

Where did it happen?

Source Location	IP address, hostname, geographic region of the origin.
Destination	Target system, service, or data store that was accessed or attacked.
Network Path	Network segment, VLAN, subnet — was it internal lateral movement or external ingress?
Physical Location	On-premises, cloud region, remote endpoint.



Who is responsible?

User Account	Username, user ID, service account involved. Was it a legitimate user or compromised account?
Process	Parent and child process information — what spawned what?
Threat Actor	If attributable: known threat group, TTPs, campaign indicators.
System Identity	Machine name, IP, MAC address, hostname of originating device.



How was it done?

Attack Vector	Phishing email, exploit, brute force, insider threat, supply chain.
Technique (ATT&CK;)	MITRE technique ID and name mapped to the observed behaviour.
Tools Used	Identified malware families, offensive tools (Mimikatz, Cobalt Strike, etc.).
Evasion Methods	Obfuscation, LOLBins (living off the land), log tampering, process injection.



Why did it happen?

Motivation	Financial gain, espionage, hacktivism, disruption, insider grievance.
Root Cause	Unpatched vulnerability, misconfiguration, weak credentials, lack of MFA.
Business Impact	Data breach, ransomware, service outage, reputational damage, regulatory penalty.
Intelligence Value	What does this incident tell us about adversary interest in our organisation?

What is a Security Operations Centre (SOC)?

A Security Operations Centre (SOC) is a centralised team and facility responsible for monitoring, detecting, analysing, and responding to cybersecurity incidents in real time. It is the nerve centre of Blue Team operations, combining people, processes, and technology (the security triad).

SOC Analyst Tiers

Tier	Role	Responsibilities	Typical Tools
Tier 1 (L1)	Alert Analyst / Triage	Monitor dashboards, triage alerts, escalate confirmed incidents	SIEM, dashboards, ticketing system, runbooks
Tier 2 (L2)	Incident Responder	Deep-dive investigation, threat correlation, malware triage	EDR, consolidation tools, Wireshark, Volatility
Tier 3 (L3)	Threat Hunter / SME	Proactive threat hunting, custom detection rules, reverse engineering	ATT&CK Navigator, YARA, Sigma rules, scripting
SOC Manager	Operations Lead	Team management, metrics, vendor relations, strategic planning	GRC platform, reporting dashboards

SOC Core Processes

Alert Triage	L1 analysts review incoming SIEM alerts. Each alert is categorised as: True Positive (TP), False Positive (FP), or Benign True Positive (BTP). Severity is assigned (Critical/High/Medium/Low).
Investigation	L2 analysts perform deep analysis of confirmed events. They correlate log sources, reconstruct the attack timeline, identify affected assets, and determine scope.
Containment	Isolate affected systems, block malicious IPs/domains, revoke compromised credentials, disable affected accounts to stop further damage.
Eradication	Remove the threat: delete malware, close persistence mechanisms (registry keys, scheduled tasks), patch the exploited vulnerability.
Recovery	Restore systems from clean backups, validate system integrity, re-enable network access, confirm monitoring is active.
Post-Incident Review	Document lessons learned, update detection rules, refine playbooks, brief stakeholders, submit threat intelligence to CTI team.

Key SOC Metrics (KPIs)

- **MTTD (Mean Time to Detect):** Average time from attack start to detection. Target: <1 hour.
- **MTTR (Mean Time to Respond):** Average time from detection to containment. Target: <4 hours.
- **MTTI (Mean Time to Investigate):** Time to complete the investigation and scope.
- **False Positive Rate:** Percentage of alerts that are not real threats. High FPR = analyst fatigue.
- **Alert Volume:** Total alerts per day — used to size the SOC team appropriately.
- **Escalation Rate:** Percentage of L1 alerts escalated to L2.
- **SLA Compliance:** Percentage of incidents resolved within agreed time windows.

Definition

Incident Response (IR) is the structured methodology for managing the lifecycle of a security incident — from preparation through detection, containment, eradication, recovery, and post-incident activity. The goal is to limit damage, reduce recovery time, and prevent recurrence. The primary frameworks are **NIST SP 800-61** and **SANS PICERL**.

NIST IR Lifecycle (SP 800-61)

Phase 1 Preparation

- Develop and maintain IR plans, policies, and playbooks.
- Provision IR tools: forensic workstations, EDR, SIEM, jump bags.
- Train the team and conduct tabletop exercises and simulations.
- Establish communication trees and escalation procedures.
- Define what constitutes an 'incident' vs. a 'security event'.

Phase 2 Detection & Analysis

- Monitor SIEM, EDR, IDS/IPS, and threat feeds for alerts.
- Validate alerts using the 5W1H framework.
- Determine the incident type: malware, data breach, insider threat, DDoS, etc.
- Assign severity level (Critical/High/Medium/Low) and open a ticket.
- Preserve evidence: memory dumps, disk images, log exports.

Phase 3 Containment

- Short-term: Isolate affected hosts from the network immediately.
- Long-term: Apply broader controls — block IoCs on firewall/proxy, reset credentials.
- Decide: take the system offline vs. maintain observation for intelligence gathering.
- Document all containment actions with timestamps.

Phase 4 Eradication

- Identify and remove the root cause: delete malware, close backdoors.
- Purge persistence mechanisms: registry run keys, cron jobs, startup scripts.
- Patch the vulnerability that enabled the compromise.
- Validate clean state using AV scan, integrity checks, and manual review.

Phase 5 Recovery

- Restore from verified clean backups or rebuild from gold image.
- Re-enable services and network access gradually with monitoring.
- Validate normal operation before closing the incident.
- Conduct regression testing to confirm the patch did not break functionality.

Phase 6 Post-Incident Activity

- Conduct a lessons-learned meeting within 1–2 weeks of closure.
- Produce a formal IR report: timeline, root cause, business impact, recommendations.
- Update detection rules, playbooks, and hardening guides.
- Share IoCs and TTPs with CTI team and relevant ISACs.

Incident Severity Classification

Severity	Criteria	Response SLA	Example
P1 – Critical	Active breach, data exfiltration, ransomware detected	Immediate – 15 min	Ransomware outbreak on production servers
P2 – High	Confirmed compromise, lateral movement detected	< 1 hour	Backdoor found on domain controller
P3 – Medium	Suspicious activity, unverified threat, policy violation	< 4 hours	Brute-force attempt from external IP
P4 – Low	Informational alert, minor policy breach	< 24 hours	USB device plugged in by authorised user

What is CTI?

Cyber Threat Intelligence (CTI) is the process of collecting, processing, analysing, and disseminating information about current and potential threats to an organisation. The goal is to transform raw data into **actionable intelligence** that improves security decision-making, prioritisation, and defence posture.

The Intelligence Lifecycle

1	Direction	Define intelligence requirements (PIRs — Priority Intelligence Requirements). What does the organisation need to know?
2	Collection	Gather data from OSINT, dark web, threat feeds, honeypots, incident data, ISACs, vendor reports.
3	Processing	Normalise, deduplicate, and structure raw data into usable formats (STIX, CSV, JSON).
4	Analysis	Apply analytical tradecraft to identify patterns, attribute actors, assess likelihood and impact.
5	Dissemination	Deliver finished intelligence to the right stakeholders in the right format at the right time.
6	Feedback	Stakeholders evaluate intelligence quality and provide feedback to refine future collection.

CTI Levels

Strategic	High-level, executive-focused intelligence about threat actor motivations, geopolitical context, and industry targeting trends. Non-technical. Informs board-level decisions.
Operational	Information about specific campaigns, adversary TTPs, and planned attacks. Used by SOC managers and IR leads to prepare defences.
Tactical	Technical IoCs — IP addresses, domain names, file hashes, Yara rules, Sigma detections. Directly consumable by security tools (SIEM, firewall, EDR).

Key CTI Standards and Formats

- **STIX (Structured Threat Information Expression):** JSON-based language for describing CTI objects (IoCs, TTPs, campaigns, threat actors).
- **TAXII (Trusted Automated Exchange of Intelligence Information):** Protocol for sharing STIX data over HTTPS.
- **MISP (Malware Information Sharing Platform):** Open-source threat intelligence platform for structured IoC sharing.
- **OpenCTI:** Open-source CTI platform for storing and correlating cyber threat intelligence.
- **YARA:** Pattern-matching language for malware identification — rule-based detection of file characteristics.
- **Sigma:** Generic SIEM rule format enabling detection rule portability across SIEM platforms.

Threat Actor Taxonomy

Category	Motivation	Sophistication	Examples
Nation-State APT	Espionage, sabotage, geopolitical influence	Very High	APT28, Lazarus Group, APT41
Cybercrime Groups	Financial gain, ransomware, fraud	High	Conti, REvil, FIN7
Hacktivists	Ideological, political, protest	Medium	Anonymous, KillNet
Insider Threat	Revenge, financial, ideological	Variable	Disgruntled employees
Script Kiddies	Notoriety, curiosity	Low	Opportunistic attackers

Log Analysis Methodology

Log analysis is the core skill of a Blue Team analyst. The objective is to extract meaningful security insight from raw event data. The methodology below provides a repeatable process applicable to any log source.

STEP 1 Collect & Centralise

Aggregate logs from all sources into a SIEM (Splunk, Elastic/ELK, Microsoft Sentinel). Ensure timestamps are normalised to UTC. Confirm log integrity and completeness — check for gaps that may indicate log tampering or shipping failures.

STEP 2 Parse & Normalise

Break raw log text into structured fields: timestamp, source IP, destination IP, user, action, result, process name, etc. Use a Common Information Model (CIM) or ECS (Elastic Common Schema) to standardise field names across all log sources.

STEP 3 Establish Baseline

Understand what 'normal' looks like for your environment. Normal login hours, expected traffic volumes, standard process parent-child chains. Without a baseline, distinguishing noise from a genuine threat is impossible.

STEP 4 Apply Detection Logic

Run correlation rules, threshold alerts, and anomaly models. Reference Sigma rules, MITRE ATT&CK; detections, and custom queries. Prioritise events that deviate significantly from the established baseline.

STEP 5 Contextualise & Correlate

Never analyse a single log in isolation. Join related events across sources. A failed login followed by a successful login followed by a new scheduled task is far more meaningful than any one event alone. Build a timeline.

STEP 6 Answer the 5W1H

Apply the framework: What happened? When? Where? Who? How? Why? Every unanswered question represents a gap in the investigation. Document the answers explicitly in the incident ticket.

STEP 7 Determine Disposition

Classify: True Positive (TP), False Positive (FP), or Benign True Positive (BTP). If TP: escalate according to severity. If FP: tune the rule. If BTP: close with documentation. Never silently dismiss an event.

Common Log Analysis Queries (Splunk SPL Examples)

Detect Failed Login Brute Force

```
index=windows EventCode=4625 | stats count by src_ip | where count > 20 | sort -count
```

Detect Pass-the-Hash (NTLM Logon Type 3 with no password)

```
index=windows EventCode=4624 Logon_Type=3 | search NOT Authentication_Package=Kerberos
```

Find Process Spawning from Office Apps

```
index=sysmon EventCode=1 | where ParentImage LIKE "%winword%" OR ParentImage LIKE "%excel%"  
| table CommandLine, Image, ParentImage
```

Detect DNS Queries to Long Subdomains (DGA)

```
index=dns | eval len=len(query) | where len > 50 | stats count by query | sort -count
```

Detect Outbound Data on Uncommon Ports

```
index=network action=allowed | where dest_port NOT IN (80,443,53,22,25) | stats  
sum(bytes_out) by src_ip, dest_port | sort -sum(bytes_out)
```

Linux Log Analysis — Key Commands

Purpose	Command
View live auth failures	<pre>tail -f /var/log/auth.log grep 'Failed'</pre>
Count failed SSH per IP	<pre>grep 'Failed password' /var/log/auth.log awk '{print \$11}' sort uniq -c sort -rn</pre>
Filter by time range	<pre>awk '/Oct 10 08:00:00/,/Oct 10 09:00:00/' /var/log/syslog</pre>
Find large file transfers	<pre>awk '{print \$7, \$10}' /var/log/nginx/access.log sort -k2 -rn head -20</pre>
Extract unique IPs from Apache log	<pre>awk '{print \$1}' /var/log/apache2/access.log sort -u</pre>
Check systemd service failures	<pre>journalctl -p err -xe --since '24 hours ago'</pre>
Find suspicious cron entries	<pre>grep -r '' /var/spool/cron/ /etc/cron* 2>/dev/null</pre>

Quick Reference — Blue Team Core Principles

1. Assume breach — operate as if adversaries are already inside. Hunt continuously.
2. Log everything — you cannot detect what you cannot see. Gaps in logging = blind spots.
3. Correlate, never isolate — single events are rarely meaningful; patterns are.
4. Document rigorously — if it isn't written down, it didn't happen.
5. Continuously improve — every incident is an opportunity to build a better defence.
6. Know your baseline — you cannot spot anomalies without knowing what normal looks like.
7. Threat-intel-driven defence — prioritise detections based on who is targeting you and how.